

Esercizio 4 - report

Versione nello stile del report NIMDA: ogni immagine viene spiegata con cosa hai fatto, cosa si vede, perche serve e risultato tecnico.

Campo	Valore
-------	--------

Scenario	Confronto HTTP plaintext vs HTTPS/TLS cifrato
Conclusione	HTTP espone admin/admin; HTTPS mostra solo Encrypted Application Data

Executive Summary

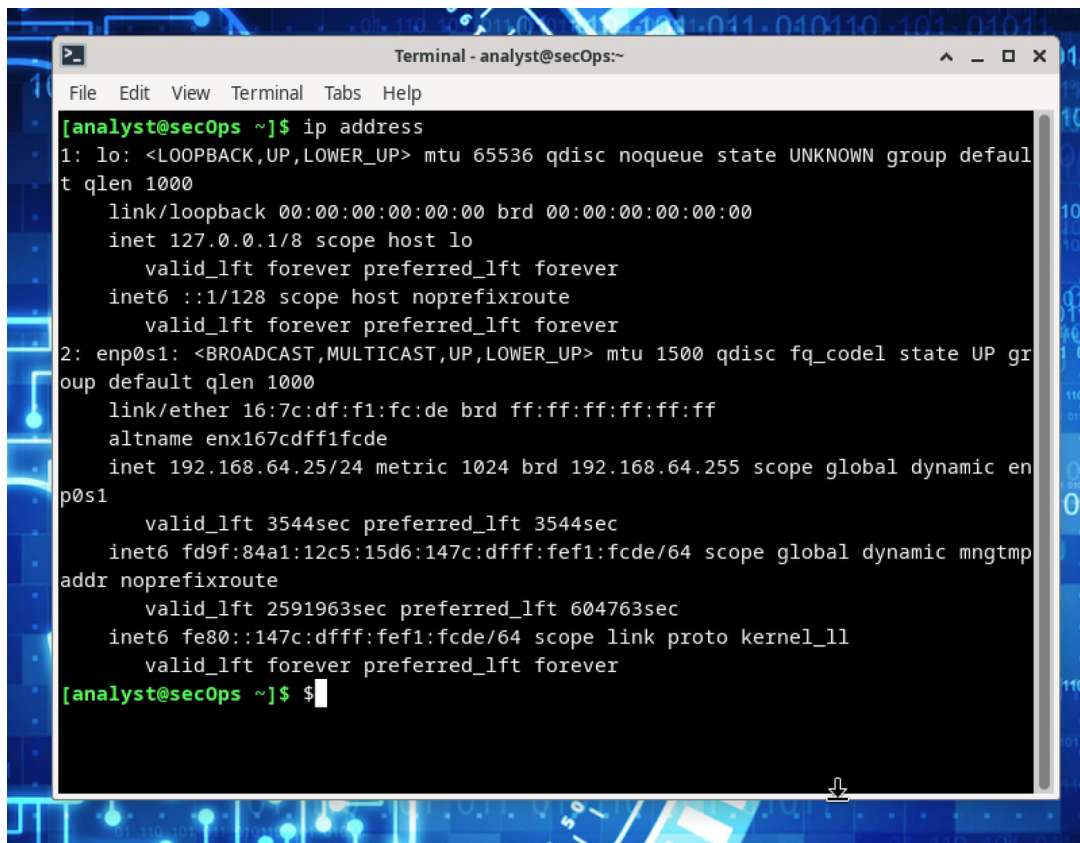
Il laboratorio dimostra con evidenze pratiche la differenza tra una sessione HTTP non cifrata e una sessione HTTPS protetta da TLS. Nella prima parte hai catturato il traffico verso test.edu.kg e hai trovato le credenziali admin/admin nel frame 6273. Nella seconda parte hai catturato il traffico verso netacad.com e hai verificato che il payload applicativo e cifrato come TLSv1.3 Encrypted Application Data.

Questa versione non salta nessuna immagine: tutte le 15 evidenze sono riportate e spiegate nel flusso cronologico dell'esecuzione.

Sequenza completa dei passaggi

- 1. Evidenza 1 - Identificazione interfaccia di rete
- 2. Evidenza 2 - Avvio cattura HTTP con tcpdump
- 3. Evidenza 3 - Login sul portale HTTP non sicuro
- 4. Evidenza 4 - Fine cattura HTTP
- 5. Evidenza 5 - Verifica file PCAP nel filesystem
- 6. Evidenza 6 - Apertura di httpdump.pcap in Wireshark
- 7. Evidenza 7 - Filtro HTTP in Wireshark
- 8. Evidenza 8 - Frame 6273 con credenziali in chiaro
- 9. Evidenza 9 - Avvio cattura HTTPS
- 10. Evidenza 10 - Accesso a sito HTTPS
- 11. Evidenza 11 - Form di login NetAcad su canale cifrato
- 12. Evidenza 12 - Verifica di httpsdump.pcap nel filesystem
- 13. Evidenza 13 - Apertura di httpsdump.pcap
- 14. Evidenza 14 - Filtro tcp.port==443 e traffico TLS
- 15. Evidenza 15 - Frame 65 con Encrypted Application Data

Evidenza 1 - Identificazione interfaccia di rete



```
Terminal - analyst@secOps:~
File Edit View Terminal Tabs Help

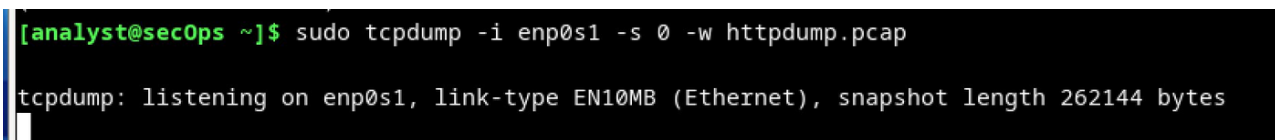
[analyst@secOps ~]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 16:7c:df:f1:fc:de brd ff:ff:ff:ff:ff:ff
    altname enx167cdf1fcde
    inet 192.168.64.25/24 metric 1024 brd 192.168.64.255 scope global dynamic enp0s1
        valid_lft 3544sec preferred_lft 3544sec
    inet6 fd9f:84a1:12c5:15d6:147c:dfff:fef1:fcde/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 2591963sec preferred_lft 604763sec
    inet6 fe80::147c:dfff:fef1:fcde/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
[analyst@secOps ~]$
```

Evidenza 1 - Identificazione interfaccia di rete - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Hai aperto il terminale su analyst@secOps ed eseguito il comando ip address per capire quale interfaccia usare nella cattura.
Cosa si vede	Si vede l'host analyst@secOps, l'interfaccia enp0s1 in stato UP, l'indirizzo IPv4 192.168.64.25/24 e i dettagli di rete come MAC address, MTU e indirizzi IPv6.
Perche serve	Questo passaggio e necessario per non catturare sull'interfaccia sbagliata. Tcpdump deve ascoltare proprio sull'interfaccia che genera il traffico web.
Risultato	Interfaccia scelta: enp0s1. Host di analisi: 192.168.64.25/24.

ip address

Evidenza 2 - Avvio cattura HTTP con tcpdump



```
analyst@secOps ~$ sudo tcpdump -i enp0s1 -s 0 -w httpdump.pcap
tcpdump: listening on enp0s1, link-type EN10MB (Ethernet), snapshot length 262144 bytes
```

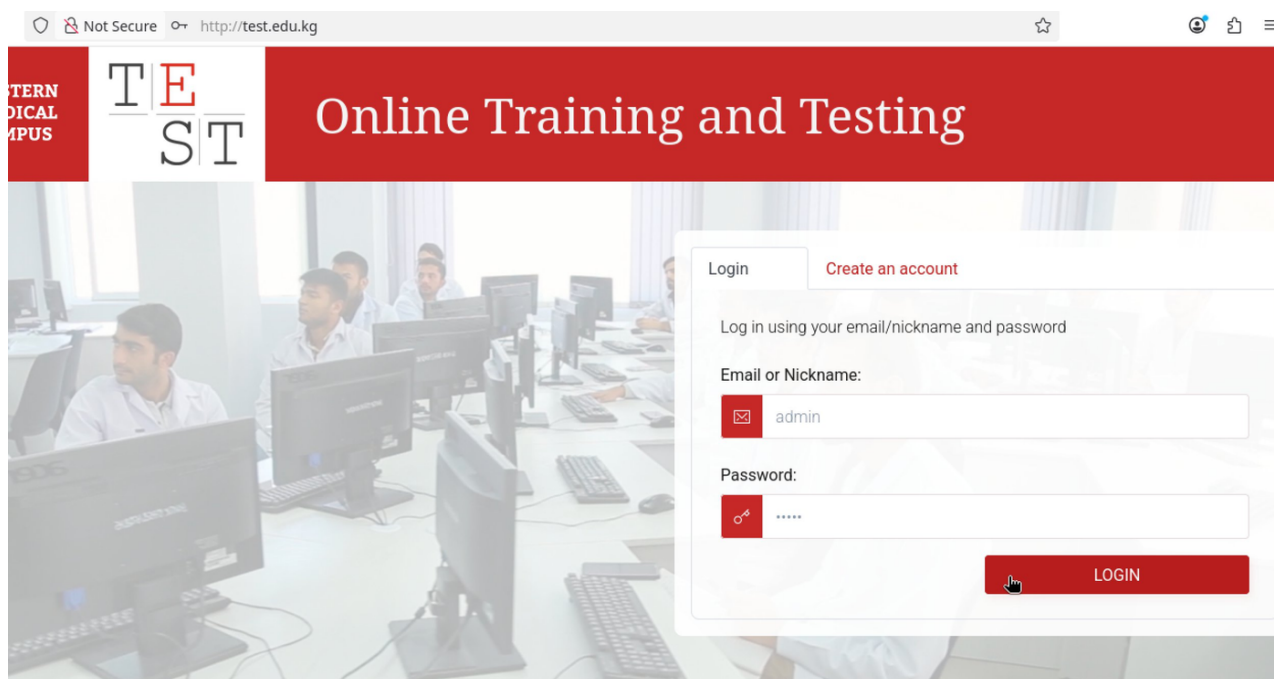
Evidenza 2 - Avvio cattura HTTP con tcpdump - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Hai avviato tcpdump sull'interfaccia enp0s1 e hai salvato tutto il traffico nel file httpdump.pcap.
Cosa si vede	Nel terminale compare tcpdump: listening on enp0s1, link-type EN10MB, snapshot length 262144 bytes.
Perche serve	Il parametro -s 0 permette di salvare il pacchetto completo, mentre -w scrive su file PCAP. Questo rende la cattura riapribile in Wireshark.

Risultato	La cattura HTTP e partita correttamente e tcpdump sta registrando il traffico.
-----------	--

```
sudo tcpdump -i enp0s1 -s 0 -w httpdump.pcap
```

Evidenza 3 - Login sul portale HTTP non sicuro

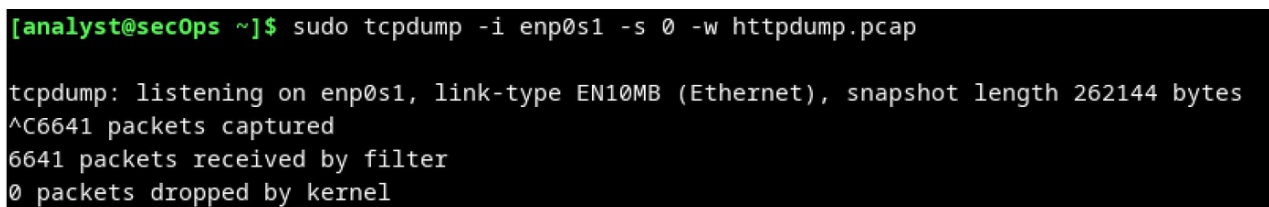


Evidenza 3 - Login sul portale HTTP non sicuro - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Hai aperto il sito <code>http://test.edu.kg</code> nel browser e hai compilato il form di login.
Cosa si vede	La barra del browser mostra Not Secure e il form Online Training and Testing contiene email/nickname admin e password admin.
Perche serve	Questa azione genera la richiesta HTTP POST che poi sarà analizzata nel PCAP. L'assenza di HTTPS indica che i dati del form viaggiano in chiaro.
Risultato	Il login genera traffico HTTP vulnerabile, adatto a dimostrare il credential sniffing.

```
Browser: http://test.edu.kg
Email/Nickname: admin
Password: admin
Click: LOGIN
```

Evidenza 4 - Fine cattura HTTP



Evidenza 4 - Fine cattura HTTP - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Dopo il login hai interrotto tcpdump con CTRL+C.
Cosa si vede	Il terminale mostra 6641 packets captured, 6641 packets received by filter e 0 packets dropped by kernel.

Perche serve	Il valore 0 dropped e importante: indica che il kernel non ha perso pacchetti durante la cattura.
Risultato	Il file httpdump.pcap e completo e affidabile per l'analisi forense del traffico HTTP.

CTRL+C

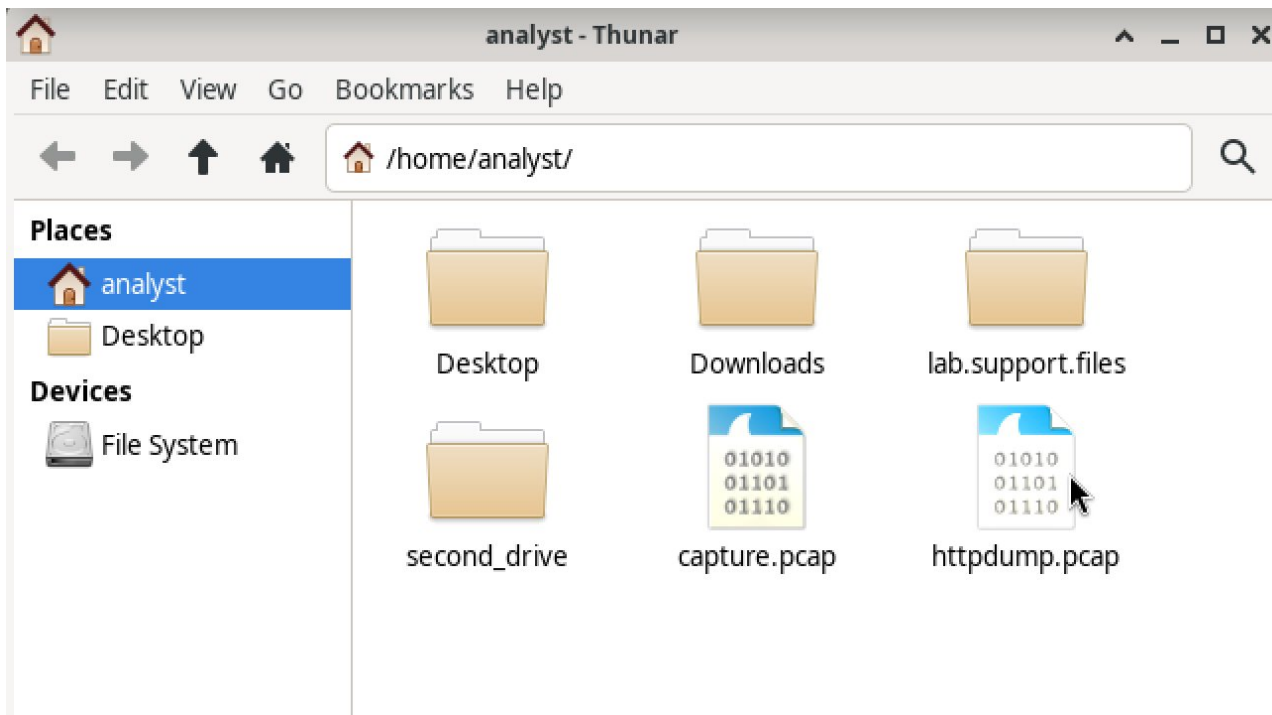
output rilevante:

6641 packets captured

6641 packets received by filter

0 packets dropped by kernel

Evidenza 5 - Verifica file PCAP nel filesystem

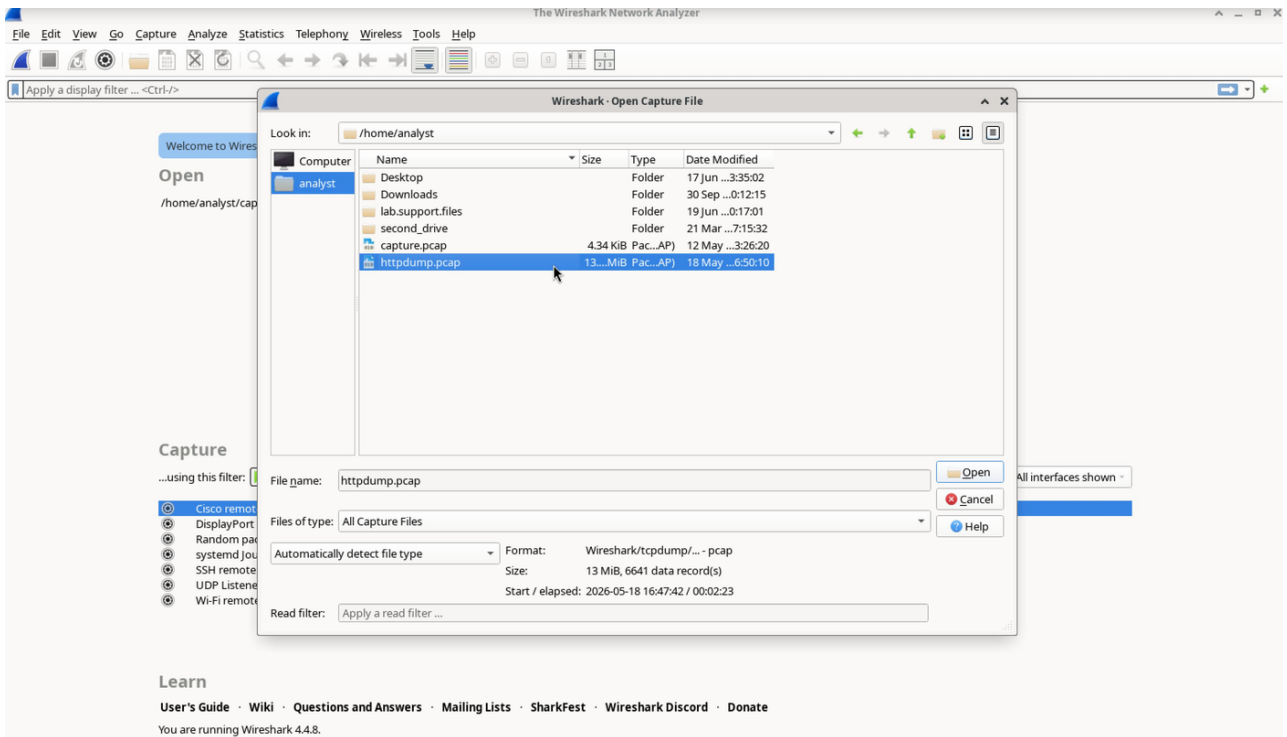


Evidenza 5 - Verifica file PCAP nel filesystem - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Hai aperto il file manager Thunar nella home dell'utente analyst.
Cosa si vede	Sono visibili capture.pcap e httpdump.pcap insieme alle cartelle Desktop, Downloads, lab.support.files e second_drive.
Perche serve	Verificare la presenza del file serve a confermare che tcpdump ha salvato realmente la cattura su disco.
Risultato	httpdump.pcap e presente in /home/analyst ed e pronto per essere aperto in Wireshark.

Percorso: /home/analyst/
File verificato: httpdump.pcap

Evidenza 6 - Apertura di httpdump.pcap in Wireshark

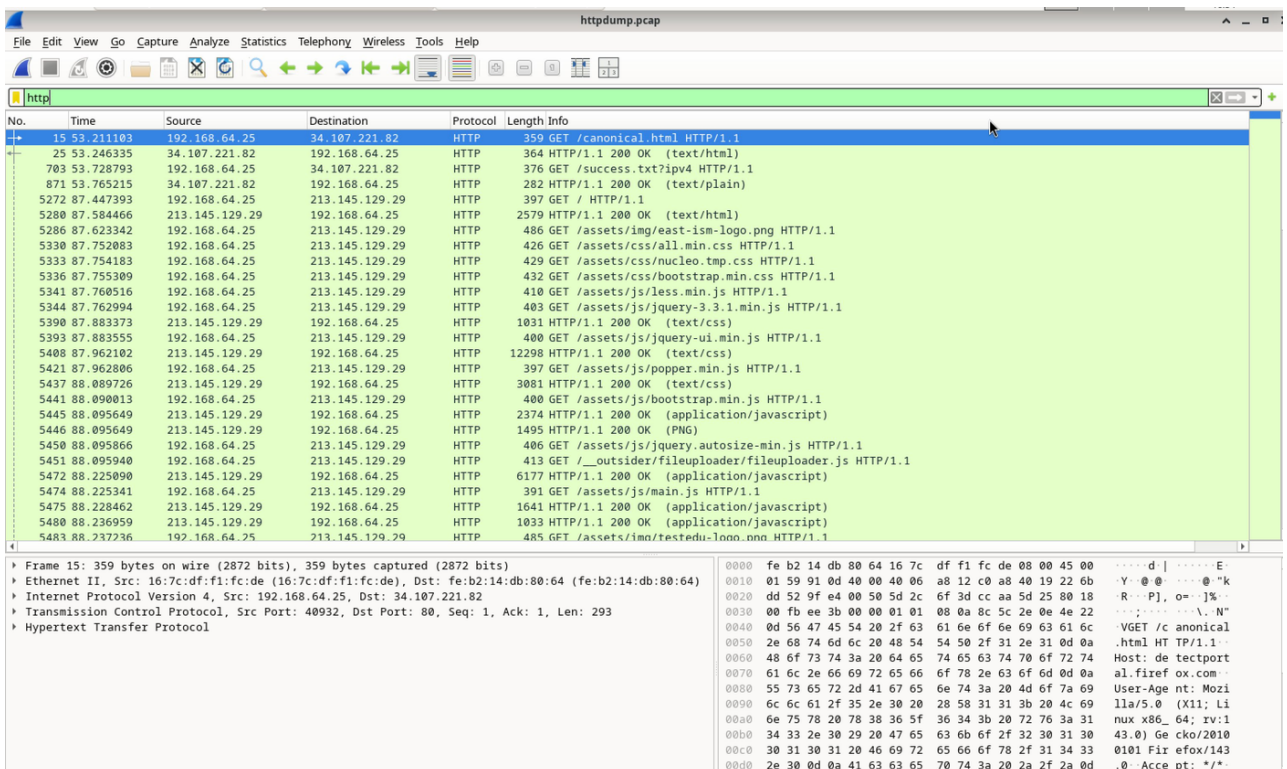


Evidenza 6 - Apertura di httpdump.pcap in Wireshark - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Hai aperto il file httpdump.pcap con Wireshark.
Cosa si vede	La finestra di apertura file mostra httpdump.pcap selezionato e un'anteprima della cattura.
Perche serve	Wireshark permette di filtrare, leggere e decodificare il traffico HTTP salvato da tcpdump.
Risultato	La cattura HTTP viene caricata e puo essere analizzata con filtri e dettagli di pacchetto.

Wireshark -> Open -> /home/analyst/httpdump.pcap

Evidenza 7 - Filtro HTTP in Wireshark

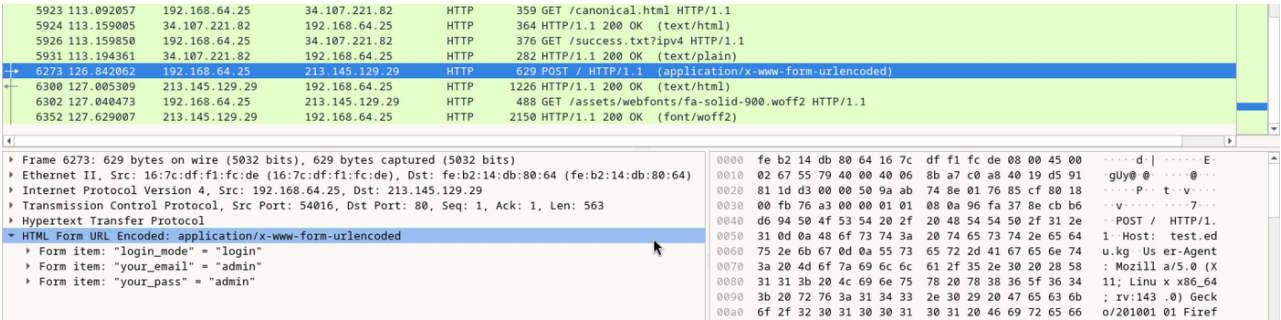


Evidenza 7 - Filtro HTTP in Wireshark - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Hai applicato il filtro http in Wireshark.
Cosa si vede	La packet list mostra richieste e risposte HTTP verso test.edu.kg, incluse risorse HTML, CSS, JavaScript e immagini.
Perche serve	Il filtro http riduce il rumore della cattura e mostra solo il traffico applicativo web in chiaro.
Risultato	Il traffico HTTP e leggibile: si vedono URL, metodi GET/POST, host, risorse richieste e risposte HTTP 200 OK.

Filtro Wireshark: http

Evidenza 8 - Frame 6273 con credenziali in chiaro



Evidenza 8 - Frame 6273 con credenziali in chiaro - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Hai selezionato il frame 6273, corrispondente alla richiesta POST di autenticazione.
Cosa si vede	Nel layer HTML Form URL Encoded si leggono login_mode=login, your_email=admin e your_pass=admin.
Perche serve	Questa e la prova principale del rischio: le credenziali sono intercettabili senza decifrare nulla.
Risultato	Credenziali esposte: admin/admin. Vulnerabilita dimostrata: trasmissione di credenziali in plaintext su HTTP.

Frame: 6273
Protocollo: HTTP
Metodo: POST
Form item: login_mode = login
Form item: your_email = admin
Form item: your_pass = admin

Evidenza 9 - Avvio cattura HTTPS

```
[analyst@secOps ~]$ sudo tcpdump -i enp0s1 -s 0 -w httpsdump.pcap
tcpdump: listening on enp0s1, link-type EN10MB (Ethernet), snapshot length 262144 bytes
```

Evidenza 9 - Avvio cattura HTTPS - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Hai avviato una seconda cattura tcpdump, questa volta salvando il traffico in httpsdump.pcap.
Cosa si vede	Il terminale mostra tcpdump in ascolto su enp0s1 con output su httpsdump.pcap.
Perche serve	Serve una cattura separata per confrontare HTTP non cifrato e HTTPS/TLS cifrato.
Risultato	La cattura HTTPS e partita correttamente e registrera il traffico verso il sito sicuro.

```
sudo tcpdump -i enp0s1 -s 0 -w httpsdump.pcap
```

Evidenza 10 - Accesso a sito HTTPS



Evidenza 10 - Accesso a sito HTTPS - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Hai navigato su https://www.netacad.com.
Cosa si vede	La barra del browser mostra il lucchetto e il prefisso https://.
Perche serve	Il lucchetto indica che il browser ha stabilito una sessione cifrata TLS con il server.
Risultato	Il traffico applicativo sara protetto: eventuali credenziali non dovrebbero essere leggibili in Wireshark.

Browser: https://www.netacad.com/

Evidenza 11 - Form di login NetAcad su canale cifrato

Welcome!

Please login to your account.

Email

mario.rossi@test.com|

[Setup or Reset Password](#)

Login

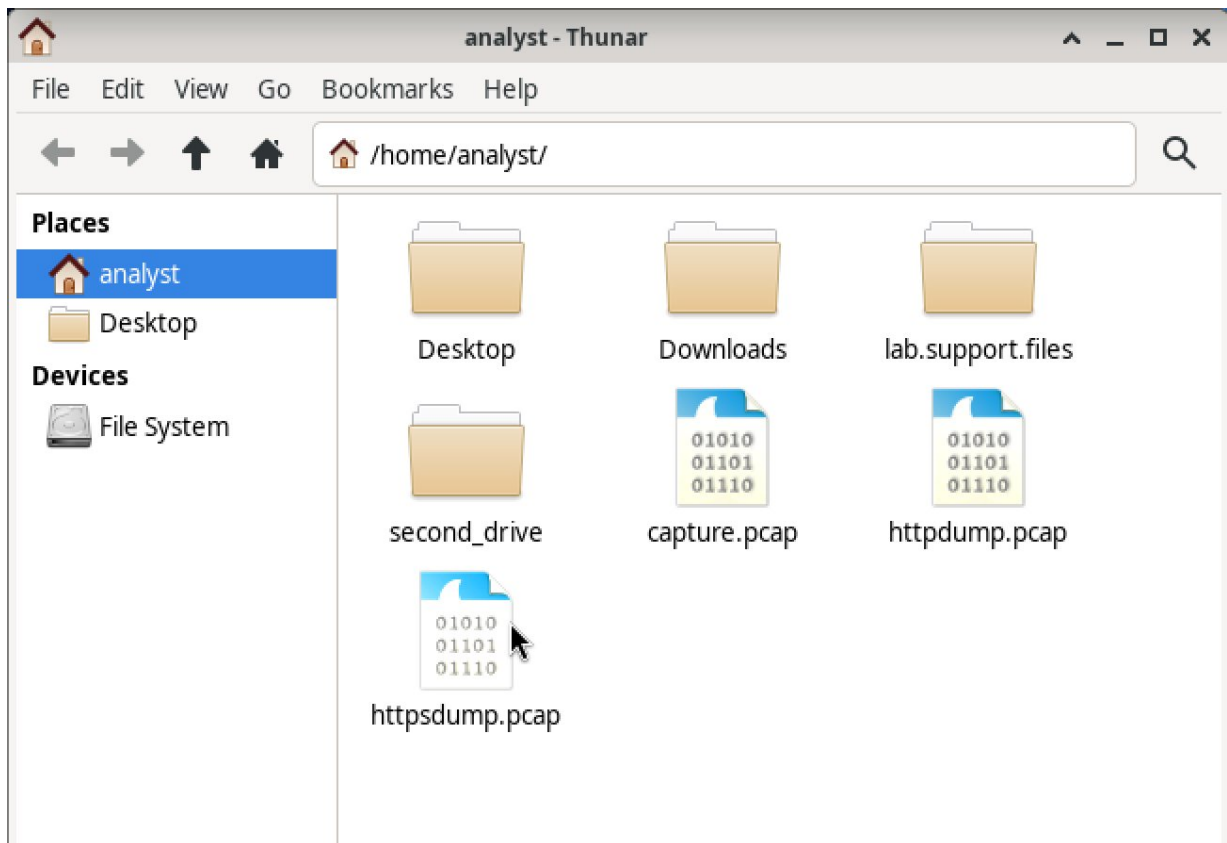
Or continue with _____

Evidenza 11 - Form di login NetAcad su canale cifrato - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Hai inserito l'email nel form di login NetAcad.
Cosa si vede	Nel campo Email compare mario.rossi@test.com e il form è servito sotto HTTPS.
Perché serve	Questo genera traffico di autenticazione, ma diversamente dal caso HTTP sarà incapsulato in TLS.
Risultato	Il dato inserito non deve comparire in plaintext nel PCAP, perché passa dentro il tunnel cifrato.

Email: mario.rossi@test.com
Click: Login
Canale: HTTPS/TLS

Evidenza 12 - Verifica di httpsdump.pcap nel filesystem

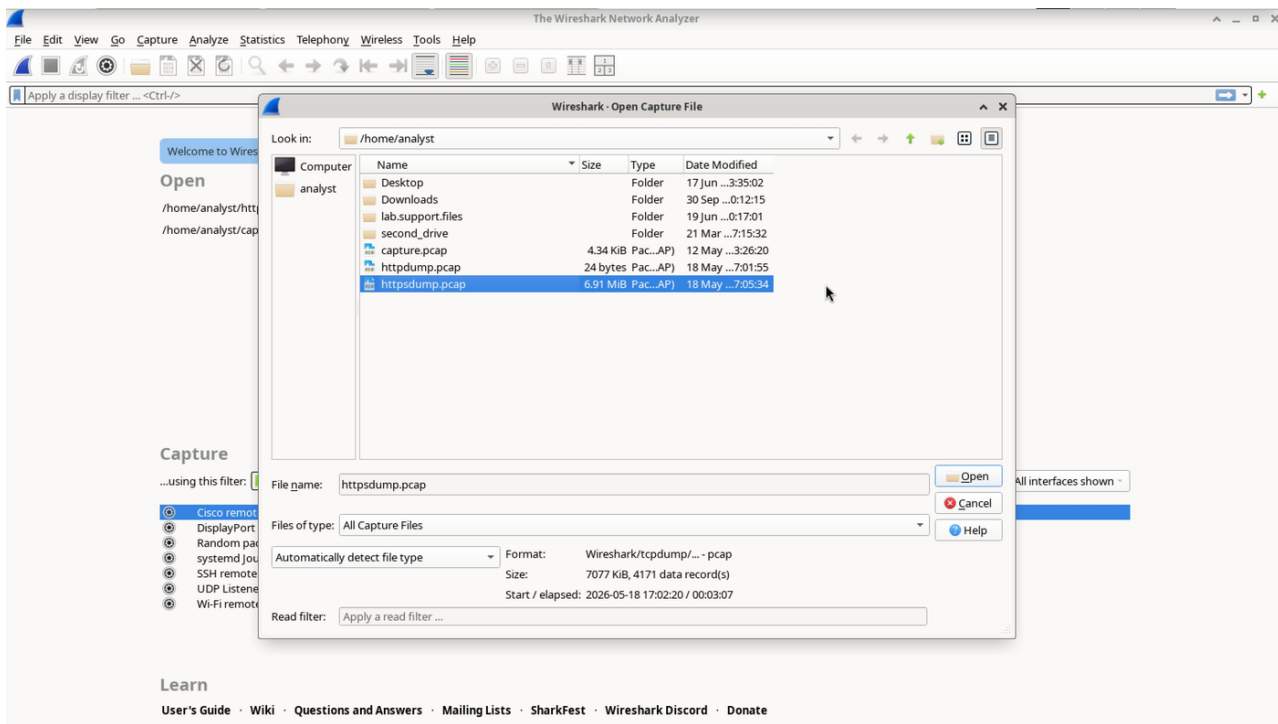


Evidenza 12 - Verifica di httpsdump.pcap nel filesystem - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Hai controllato di nuovo la home dell'utente analyst con il file manager.
Cosa si vede	Ora sono presenti capture.pcap, httpdump.pcap e httpsdump.pcap.
Perche serve	Conferma che anche la seconda cattura e stata salvata correttamente.
Risultato	httpsdump.pcap e disponibile per l'analisi comparativa in Wireshark.

Percorso: /home/analyst/
File verificato: httpsdump.pcap

Evidenza 13 - Apertura di httpsdump.pcap

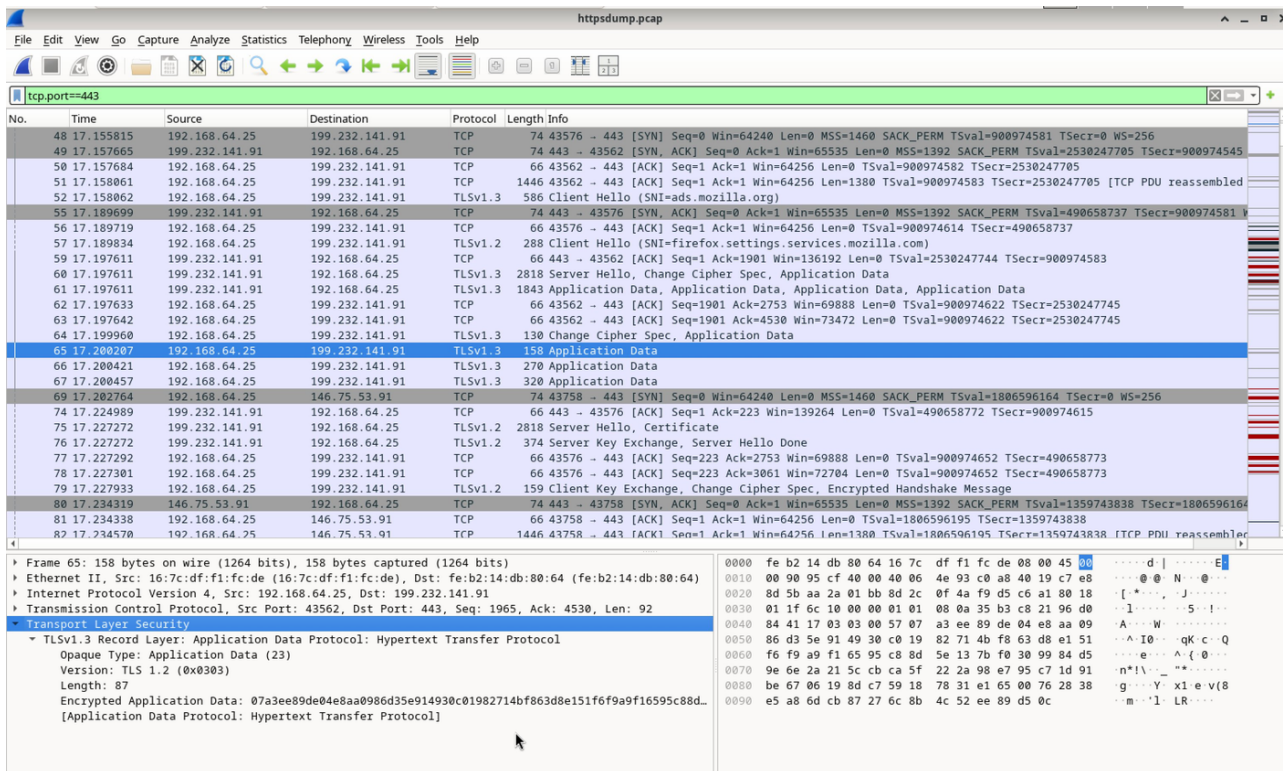


Evidenza 13 - Apertura di httpsdump.pcap - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Hai aperto httpsdump.pcap in Wireshark.
Cosa si vede	La finestra di apertura mostra httpsdump.pcap selezionato, con anteprima e metadati della cattura.
Perche serve	Aprire la cattura HTTPS permette di verificare se il traffico applicativo e leggibile oppure cifrato.
Risultato	La cattura HTTPS viene caricata per l'analisi con filtro tcp.port==443.

Wireshark -> Open -> /home/analyst/httpsdump.pcap

Evidenza 14 - Filtro tcp.port==443 e traffico TLS

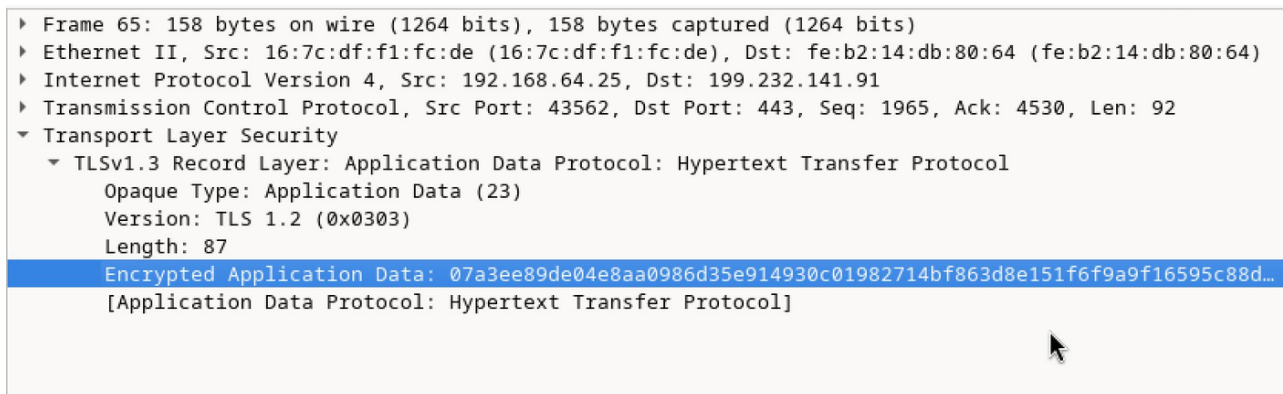


Evidenza 14 - Filtro tcp.port==443 e traffico TLS - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Hai applicato il filtro tcp.port==443 in Wireshark.
Cosa si vede	Si vedono pacchetti TLSv1.2/TLSv1.3, Client Hello, Server Hello, Certificate, Change Cipher Spec e Application Data.
Perche serve	Il filtro 443 mostra il traffico HTTPS. A differenza del filtro http, qui non si leggono form e credenziali.
Risultato	Wireshark mostra metadata TLS e pacchetti cifrati, non il contenuto applicativo in chiaro.

Filtro Wireshark: tcp.port==443

Evidenza 15 - Frame 65 con Encrypted Application Data



Evidenza 15 - Frame 65 con Encrypted Application Data - immagine reale estratta dal report originale.

Voce	Spiegazione
Cosa hai fatto	Hai selezionato il frame 65 per vedere il dettaglio del payload TLS.
Cosa si vede	Nel layer Transport Layer Security compare TLSv1.3 Record Layer: Application Data Protocol: Hypertext Transfer Protocol e il campo Encrypted Application Data.

Perche serve	Questa e la prova del confronto: il traffico web esiste, ma e cifrato e non rivela email, password o contenuto del form.
Risultato	Con HTTPS l'attaccante vede solo byte cifrati. Il dato applicativo non e leggibile senza chiavi di sessione.

Frame: 65
Protocollo: TLSv1.3
Campo chiave: Encrypted Application Data
Risultato: payload non leggibile

Analisi finale HTTP vs HTTPS

Elemento	HTTP - test.edu.kg	HTTPS - netacad.com
Cattura	httpdump.pcap	httpsdump.pcap
Filtro	http	tcp.port==443
Dati applicativi	Plaintext leggibile	Cifrati in TLS
Evidenza critica	Frame 6273: your_email=admin, your_pass=admin	Frame 65: Encrypted Application Data
Rischio	Credential sniffing immediato	Credenziali non recuperabili dal PCAP

Conclusione

Tutti i passaggi dimostrano la catena completa: scelta interfaccia, cattura HTTP, login vulnerabile, analisi del frame POST, cattura HTTPS, verifica del traffico TLS e confronto finale. La prova pi importante e il contrasto fra il frame 6273, dove le credenziali sono in chiaro, e il frame 65, dove il contenuto e cifrato. La remediation e rendere HTTPS obbligatorio, eliminare credenziali di default e configurare HSTS, MFA e controlli SIEM.